Entrega Final: Documento de Seguridad y Resiliencia

Proyecto: Coder House IA Automation – Flujo de clasificación de mensajes recibidos por canal email de una tienda on line (Spam / Soporte / Lead)

Plataforma de automatización: n8n

Agente de IA: Claude (Claude Sonnet 5)

1. Propósito y alcance

El presente documento describe las medidas de seguridad y resiliencia de la solución de automatización implementada, cuya función principal es leer los correos entrantes de la bandeja de la tienda en línea, clasificarlos con un agente de IA apoyado en un RAG y ejecutar acciones según el resultado.

En el presente documento, se define qué se protege, se identificarán los riesgos existentes, así como se deberán mitigar los mismos y adicionalmente, cómo se recuperará la operación ante fallos.

Para este análisis, se contemplará el siguiente alcance:

Dentro del alcance: flujo en n8n, agente de IA (Claude Sonnet 5), base de conocimiento del RAG, conexión con la bandeja de correo, generación de borradores, envío de respuesta al cliente y notificaciones en Slack.

Fuera del alcance: seguridad del proveedor de correo, de Slack y de Claude Sonnet 5 más allá de los controles que configura el equipo del proyecto.

2. Descripción de la solución

2.1 Flujo general

1. **Captura:** un nodo disparador (Gmail Trigger o equivalente) detecta cada correo nuevo en la bandeja.
2. **Clasificación:** un nodo AI Agent con el modelo Claude analiza el correo y consulta el RAG (base de conocimiento) para decidir si es **Spam**, **Soporte** o **Lead**.
3. **Salida estructurada:** un Structured Output Parser obliga al agente a responder con un formato fijo (mensaje, clasificación, fecha, correo).
4. **Enrutamiento:** un nodo Switch/IF dirige el correo según la clasificación.
    - **Spam:** se etiqueta como spam y no se responde.
    - **Lead:** se genera un borrador de respuesta comercial y se notifica al personal humano por el canal de Slack sobre el borrador generado, solicitando aprobación o rechazo.
    - **Soporte:** se envía respuesta automática al cliente, indicando que será atendida su solicitud en breve por un analista y se notifica por Slack al grupo de soporte que un cliente requiere atención.
5. **Supervisión humana:** los borradores quedan guardados para revisión; no se envían automáticamente.

2.2 Componentes

Componente	Función	Dato sensible que maneja
n8n	Orquestación del flujo	Credenciales, contenido de correos en ejecuciones
Claude (API de Claude Sonnet 5)	Clasificación y redacción de borradores	Contenido de los correos
Base de conocimiento RAG	Criterios de clasificación y políticas de la tienda	Información interna del negocio
Gmail / bandeja de correo	Origen de los mensajes y destino de borradores	Datos personales de clientes
Slack	Alertas de soporte	Resumen del caso y datos de contacto

2.3 Datos que circulan

Nombre y correo del remitente, asunto y cuerpo del mensaje, posibles datos de pedidos o reclamos, clasificación asignada y fecha. Se clasifican como datos personales de nivel medio; no se espera procesar datos de pago ni documentos de identidad, y el flujo debe evitar procesarlos si llegan por error.

3. Análisis de riesgos

Escala: Probabilidad e Impacto en Bajo / Medio / Alto.

#	Riesgo	Prob.	Impacto	Mitigación principal
R1	Prompt injection: un correo con instrucciones ocultas manipula al agente	Media	Alto	Aislar el contenido del correo como dato, salida estructurada validada, sin acciones irreversibles automáticas
R2	Falso positivo: cliente real clasificado como spam y no atendido	Media	Alto	Ruta de revisión manual, muestreo periódico de spam, umbral de confianza
R3	Falso negativo:	Media	Bajo	Reglas de filtrado

#	Riesgo	Prob.	Impacto	Mitigación principal
	spam llega a Slack o genera borradores			previas, ajuste del prompt y del RAG
R4	Alucinación en el borrador (promete reembolsos, plazos o políticas inexistentes)	Media	Alto	Borradores solo desde el RAG, revisión humana obligatoria, prohibición de compromisos en el prompt
R5	Fuga de datos personales hacia el modelo, logs o Slack	Media	Alto	Minimización de datos, enmascaramiento, retención corta de ejecuciones
R6	Credenciales expuestas (Gmail, Slack, API de Claude)	Baja	Alto	Almacén de credenciales de n8n, mínimo privilegio, rotación
R7	Caída o lentitud de la API de Claude, Gmail o Slack	Media	Medio	Reintentos, fallback a revisión manual, alertas
R8	Límites de uso (rate limit) o sobrecosto por picos de correos o ataques de volumen	Media	Medio	Límites de concurrencia, tope de gasto, lotes
R9	Duplicados: un correo procesado dos veces genera dos borradores o dos alertas	Media	Bajo	Idempotencia con etiqueta de procesado
R10	Pérdida o corrupción del	Baja	Alto	Exportación versionada y

#	Riesgo	Prob.	Impacto	Mitigación principal
	flujo o del RAG			respaldos
R11	Acceso no autorizado a n8n o a la base de conocimiento	Baja	Alto	Roles, 2FA, HTTPS, acceso restringido

4. Controles de seguridad

4.1 Gestión de credenciales y secretos

- Todas las claves (API de Claude Sonnet 5, OAuth de Gmail, token de Slack) se guardan en el almacén de credenciales de n8n, nunca escritas en nodos, expresiones, código ni en el prompt.
- Se configura una clave de cifrado propia para n8n (variable `N8N_ENCRYPTION_KEY`) y se respalda por separado, ya que sin ella no se pueden recuperar las credenciales.
- Las claves se rotan de forma periódica y de inmediato ante cualquier sospecha de exposición.
- Se usa una clave de API de Claude Sonnet 5 dedicada a este proyecto, con límite de gasto configurado en la consola, para poder revocarla sin afectar otros sistemas.

4.2 Mínimo privilegio

- **Gmail:** permisos solo para leer, etiquetar y crear borradores. No se otorga permiso de envío automático.
- **Slack:** aplicación con acceso únicamente al canal de alertas de soporte (por ejemplo, #soporte-alertas).
- **n8n:** el flujo se ejecuta con una cuenta de servicio, no con la cuenta personal de un integrante.
- El agente de IA no tiene herramientas con efectos destructivos (no borra correos, no envía, no modifica pedidos). Sus únicas herramientas son la consulta al RAG.

4.3 Defensa ante prompt injection

El contenido de un correo es una entrada no confiable. Medidas:

- En el prompt del sistema se indica explícitamente que el texto del correo es **dato a clasificar, nunca instrucciones**, y que debe ignorarse cualquier orden contenida en él.
- El correo se entrega delimitado (por ejemplo, entre etiquetas `<correo>…</correo>`), separado de las instrucciones del sistema.
- La salida pasa por el **Structured Output Parser**: si la clasificación no es exactamente `Spam`, `Lead` o `Soporte`, o falta algún campo, el flujo no ejecuta acciones y envía el caso a revisión manual.
- Las acciones posibles están limitadas por diseño (etiquetar, crear borrador, notificar), por lo que una manipulación exitosa tiene impacto acotado.
- Los enlaces y adjuntos del correo no se abren ni se ejecutan automáticamente.

4.4 Protección de datos personales

- **Minimización:** al modelo se envían solo asunto, cuerpo (truncado a una longitud máxima) y remitente; no se envían adjuntos ni cabeceras completas.
- **Slack:** la alerta incluye solo el resumen del caso, la categoría y un enlace al correo; no se copia el cuerpo completo.
- **Retención en n8n:** se activa la limpieza automática de ejecuciones antiguas y se evita guardar los datos de ejecuciones exitosas cuando no son necesarios para auditoría (variables `EXECUTIONS_DATA_PRUNE`, `EXECUTIONS_DATA_MAX_AGE` y opciones de guardado de ejecuciones).
- **Proveedor de IA:** se revisan los términos de uso de datos y retención de Claude Sonnet 5 para la API comercial y se documenta el resultado. Se debe confirmar la política vigente en el momento del despliegue.
- **Normativa:** tratamiento acorde con la Ley 1581 de 2012 (protección de datos personales en Colombia), con finalidad declarada (atención de correos del negocio) y acceso limitado a quienes lo requieren. Si la tienda opera con clientes de otras jurisdicciones, validar los requisitos aplicables.

4.5 Control de acceso e infraestructura de n8n

- Acceso a n8n con usuarios individuales, roles diferenciados (administrador, editor, solo lectura) y autenticación en dos pasos.
- n8n Cloud: se apoya en los controles del proveedor y se activan las opciones de seguridad de la cuenta.
- La edición del **RAG** (base de conocimiento) se restringe a responsables definidos, ya que un contenido alterado puede cambiar las decisiones del agente.

4.6 Calidad y seguridad de las respuestas del agente

- El prompt prohíbe asumir compromisos (reembolsos, plazos, descuentos) que no estén en el RAG.
- Si el RAG no tiene información suficiente, el borrador debe indicarlo con una fórmula neutra y marcar el caso para revisión.
- Temperatura baja para la clasificación (resultados más consistentes).
- Human in the loop: ningún borrador se envía sin aprobación de una persona.

5. Resiliencia y continuidad operativa

5.1 Manejo de errores en n8n

- En los nodos críticos (Claude, Gmail, Slack) se activa Retry On Fail con 3 intentos y espera creciente entre ellos.
- Se configura un Error Workflow con un nodo Error Trigger que envía una alerta al canal de monitoreo de Slack con el nombre del flujo, el nodo que falló y el enlace a la ejecución.
- En los nodos de IA y de Slack se usa Continue On Fail / ruta de error para que un fallo no detenga todo el procesamiento.

5.2 Fallbacks por escenario

Escenario de falla	Comportamiento esperado
La API de Claude no responde o devuelve error	Reintentos; si persisten, el correo se etiqueta **"Revisión manual"** y se alerta al equipo
El agente responde fuera del formato esperado	Se descarta la salida, se etiqueta "Revisión manual" y se registra el caso
Slack no está disponible	Reintentos; si falla, se envía la alerta por correo interno al responsable de soporte
Gmail devuelve error al crear el borrador	Reintento; si falla, se notifica en Slack con el enlace al correo original
El RAG no está disponible	La clasificación continúa solo con las reglas del prompt y se marca con menor confianza para revisión
Caída total de n8n	Se aplica el plan manual (sección 5.5)

5.3 Control de duplicados

- Al terminar el procesamiento, cada correo recibe una etiqueta. El flujo ignora los correos que ya la tienen.
- Se usa el identificador único del mensaje como clave para evitar que un reintento o una reactivación del flujo genere borradores o alertas duplicadas.

5.4 Límites, costos y picos de carga

- Se limita la concurrencia del flujo y se procesan los correos en lotes pequeños para no superar los límites de uso de la API.
- Ante un pico inusual (por ejemplo, un ataque de spam masivo), una regla previa filtra remitentes y patrones obvios antes de llamar al modelo, para reducir costo y riesgo.
- Se configuran un tope de gasto y alertas de consumo en la cuenta de Claude Sonnet 5.
- Los borradores generados no se envían hasta tener la aprobación del humano, previa revisión manual.

5.5 Respaldo, recuperación y plan de contingencia

Elemento	Medida	Frecuencia
Flujos de n8n	Exportación en JSON y versionado (por ejemplo, en un repositorio privado)	Tras cada cambio
Credenciales y clave de cifrado	Respaldo seguro de `N8N_ENCRYPTION_KEY` en gestor de secretos, separado de los	Al crearse y al rotar

Elemento	Medida	Frecuencia
	flujos	
Base de datos de n8n (si es autoalojado)	Respaldo automático	Diario
Base de conocimiento del RAG	Copia de los documentos fuente y del índice	Semanal y tras cambios
Prompt y configuración del agente	Versionado junto al flujo	Tras cada cambio

Objetivos de recuperación (propuestos):

- **RTO** (tiempo máximo para restablecer el servicio): 4 horas hábiles.
- **RPO** (pérdida máxima de datos aceptable): 24 horas para la configuración; 0 para correos, que permanecen en la bandeja de origen y pueden reprocesarse.

Plan manual durante una caída: el responsable de soporte revisa directamente la bandeja, atiende primero los correos sin etiqueta y, al restablecerse el flujo, se reprocesan los pendientes.

6. Pruebas de seguridad y resiliencia

Antes de pasar a producción se verifican, y se repiten tras cambios importantes:

1. **Casos de clasificación:** conjunto de correos de prueba representativos de spam, soporte y leads, incluyendo casos ambiguos.
2. **Salida inválida:** simulación de respuestas del modelo fuera de formato para comprobar la ruta de revisión manual.
3. **Fallo de servicios:** desconexión simulada de Claude, Slack y Gmail para validar reintentos, alertas y fallbacks.
4. **Duplicados:** reejecución sobre correos ya procesados para confirmar que no se generan acciones repetidas.
5. **Carga:** envío de un lote grande de correos para validar los límites de concurrencia y de gasto.
6. **Recuperación:** restauración de un respaldo del flujo y de las credenciales en un entorno de prueba.

7. Gobernanza y gestión de incidentes

7.1 Roles

Rol	Responsabilidad
Responsable del flujo	Mantenimiento de n8n, prompts, RAG y respaldos

Rol	Responsabilidad
Responsable de soporte	Atiende alertas de Slack y revisa los borradores
Responsable de seguridad / datos	Revisa accesos, credenciales y cumplimiento de la política de datos

7.2 Respuesta a incidentes

1. **Detectar:** alerta automática o reporte de un usuario.
2. **Contener:** desactivar el flujo, revocar o rotar las credenciales comprometidas.
3. **Evaluar:** determinar qué datos o correos se vieron afectados.
4. **Corregir:** aplicar la solución y probarla antes de reactivar.
5. **Comunicar:** informar a los responsables y, si hubo datos personales comprometidos, cumplir los deberes de notificación aplicables.
6. **Aprender:** documentar la causa y actualizar controles y pruebas.

8. Resumen de controles clave

- Credenciales en el almacén de n8n, con mínimo privilegio y sin envío automático de correos.
- El contenido del correo se trata como dato, con salida estructurada validada.
- Revisión humana de todos los borradores.
- Reintentos, rutas de error y fallback a revisión manual.
- Idempotencia mediante etiqueta de procesado.
- Respaldos versionados, con RTO y RPO definidos.
- Monitoreo, alertas y muestreo periódico de calidad.